

**FACULDADE DE TECNOLOGIA SENAC RIO
TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS**

**FRANCISCO GIULIANNI DUARTE DA SILVA
ISABEL MARÇANO MOURA DA PAZ
LUCAS ALVES DA CRUZ
LUCAS MEIRELLES BARBOSA BORGES**

FUNÇÃO DO AUDITOR E TÉCNICAS DE AUDITORIA

SPRINT III

RIO DE JANEIRO

2026

1 INTRODUÇÃO

A auditoria de Tecnologia da Informação possui papel fundamental no cenário atual, em que organizações dependem cada vez mais de sistemas digitais para executar suas atividades, armazenar informações e tomar decisões estratégicas. Com o aumento da complexidade dos ambientes tecnológicos, tornou-se necessário estabelecer mecanismos capazes de avaliar se os sistemas, processos e controles internos estão funcionando de forma adequada.

Nesse contexto, o auditor de TI atua como um profissional responsável por examinar, avaliar e fornecer recomendações relacionadas aos recursos tecnológicos de uma organização. Sua função envolve analisar riscos, verificar a conformidade dos processos e identificar oportunidades de melhoria.

Além disso, para realizar uma auditoria eficiente, são utilizadas diversas técnicas de investigação e coleta de evidências, permitindo que o auditor obtenha informações confiáveis para fundamentar suas conclusões.

2 DESENVOLVIMENTO

2.1 Função do Auditor de Tecnologia da Informação

O auditor de Tecnologia da Informação é o profissional responsável por avaliar a eficiência, segurança e conformidade dos sistemas e processos tecnológicos de uma organização.

Sua atuação não se limita apenas à identificação de erros ou falhas, mas envolve uma análise ampla do ambiente tecnológico, considerando riscos, controles internos, políticas de segurança e objetivos estratégicos da empresa.

Entre as principais responsabilidades do auditor estão:

- avaliar controles internos;
- identificar riscos tecnológicos;
- verificar conformidade com normas e políticas;
- analisar a segurança dos sistemas;
- propor melhorias nos processos;
- elaborar relatórios com recomendações.

O auditor deve possuir conhecimento técnico e capacidade analítica, pois precisa compreender tanto os aspectos tecnológicos quanto os processos de negócio envolvidos.

Segundo boas práticas internacionais de auditoria, a atuação do auditor deve ser independente e imparcial, garantindo que os resultados obtidos sejam baseados em evidências e não em opiniões pessoais.

2.2 Evolução do Auditor de TI

A função do auditor passou por diversas transformações ao longo do tempo.

Inicialmente, a auditoria de sistemas era voltada principalmente para a verificação de registros eletrônicos e funcionamento básico dos sistemas.

Com a evolução da tecnologia, novas preocupações surgiram, como:

- segurança da informação;
- proteção de dados;
- ataques cibernéticos;
- disponibilidade dos sistemas;
- governança de TI;
- continuidade dos negócios.

Dessa forma, o auditor deixou de atuar apenas como fiscalizador e passou a exercer uma função estratégica, auxiliando organizações na prevenção de riscos e melhoria dos processos tecnológicos.

2.3 Planejamento de Auditoria

O planejamento é uma das etapas mais importantes de uma auditoria, pois define como o trabalho será realizado.

Antes de iniciar a análise, o auditor deve estabelecer:

- objetivos da auditoria;
- escopo do trabalho;
- sistemas e processos avaliados;
- critérios utilizados;
- riscos envolvidos;
- recursos necessários.

Um planejamento adequado permite que a auditoria seja realizada de forma organizada, reduzindo falhas e aumentando a qualidade dos resultados.

Durante essa fase também são definidos os procedimentos que serão utilizados para coletar evidências e avaliar os controles existentes.

2.3 Técnicas de Coleta de Evidências

Para chegar a conclusões confiáveis, o auditor precisa obter evidências suficientes e adequadas.

As principais técnicas utilizadas são:

2.4.1 Entrevistas

As entrevistas consistem na obtenção de informações diretamente com colaboradores, gestores e responsáveis pelos processos analisados.

Elas permitem ao auditor compreender:

- como os processos funcionam;
- quais controles existem;
- quais dificuldades são encontradas;
- quais riscos podem estar presentes.

As entrevistas podem ser:

Estruturadas: seguem perguntas previamente definidas.

Semi estruturadas: possuem perguntas planejadas, mas permitem aprofundamentos.

Não estruturadas: possuem formato mais livre de conversa.

Apesar de serem importantes, as informações obtidas devem ser confirmadas por outras evidências.

2.4.2 Análise Documental

A análise documental consiste na avaliação de documentos, registros e informações produzidas pela organização.

Podem ser analisados:

- políticas de segurança;
- procedimentos internos;
- relatórios;
- registros de sistemas;
- contratos;
- logs;

- documentos técnicos.

Essa técnica permite verificar se os processos estão documentados corretamente e se seguem normas estabelecidas.

Sua principal vantagem é fornecer evidências formais e rastreáveis.

2.4.3 Observação In Loco

A observação in loco consiste no acompanhamento direto das atividades realizadas dentro do ambiente auditado.

Por meio dela, o auditor verifica se os procedimentos descritos realmente são executados na prática.

Pode ser utilizada para avaliar:

- controle de acesso;
- processos de backup;
- segurança física;
- gerenciamento de mudanças;
- atividades operacionais.

Essa técnica permite identificar diferenças entre o processo documentado e a realidade operacional.

2.5 Testes de Controle

Os testes de controle têm como objetivo verificar se os mecanismos implementados pela organização estão funcionando corretamente.

Eles permitem avaliar se os controles existentes conseguem reduzir riscos e proteger os ativos tecnológicos.

Os controles podem ser classificados em:

Controles Preventivos: São utilizados para evitar que problemas aconteçam.

Exemplos:

- políticas de senha;
- autenticação multifator;
- controle de acesso;
- treinamentos de segurança.

Controles Detectivos: Buscam identificar problemas que já ocorreram ou estão ocorrendo.

Exemplos:

- análise de logs;
- monitoramento de sistemas;
- auditorias periódicas.

Controles Corretivos: Atuam após a identificação de falhas, buscando recuperar os serviços.

Exemplos:

- restauração de backups;
- correção de vulnerabilidades;
- planos de recuperação.

2.6 Relatório de Auditoria

O relatório de auditoria é o documento final produzido pelo auditor, responsável por apresentar os resultados encontrados durante o trabalho.

Ele deve conter:

- objetivo da auditoria;
- escopo analisado;
- metodologia utilizada;
- evidências coletadas;
- problemas encontrados;
- recomendações.

Um bom relatório deve ser:

- claro;
- objetivo;
- imparcial;
- baseado em evidências.

Além de registrar os resultados, ele auxilia gestores na tomada de decisões e na implementação de melhorias.

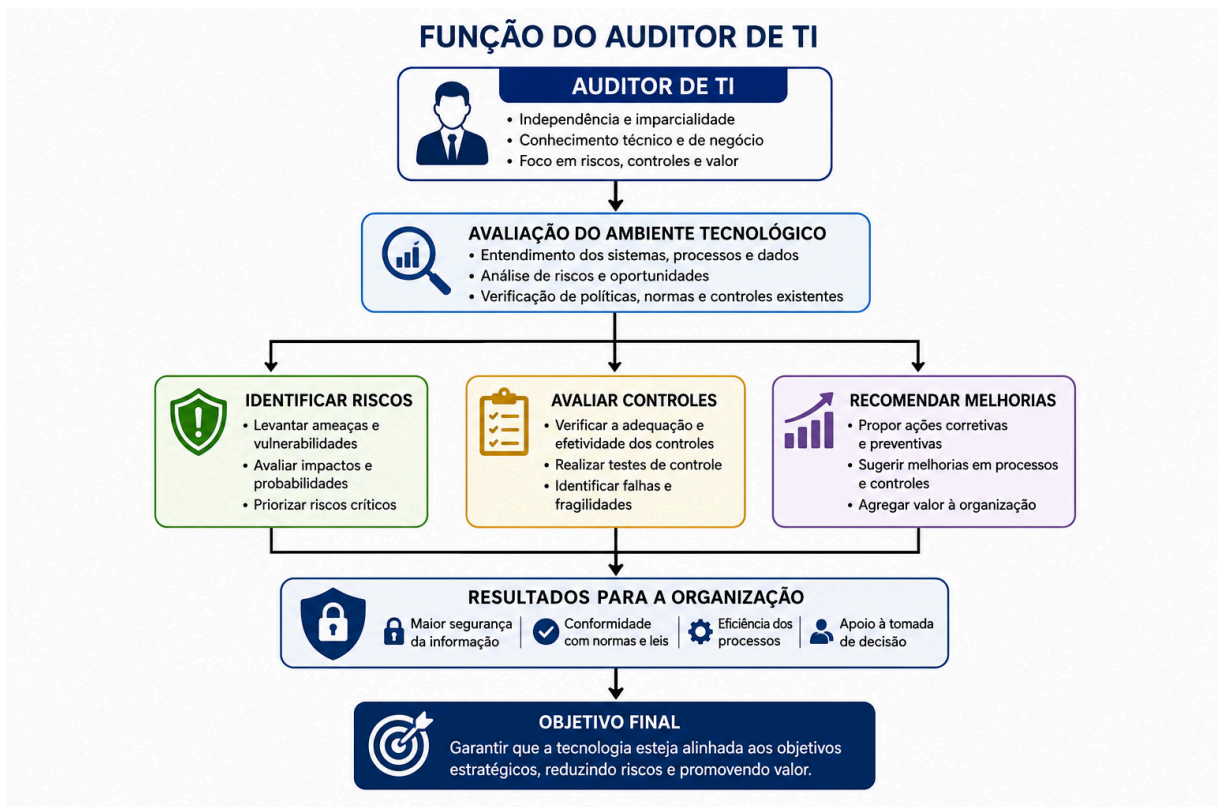
2.7 Diagrama do Processo de Auditoria de TI

A auditoria de Tecnologia da Informação segue um processo estruturado, no qual cada etapa contribui para a obtenção de resultados confiáveis.



O processo inicia com o planejamento, onde o auditor define o que será analisado. Em seguida, ocorre a coleta de evidências utilizando diferentes técnicas. Após a avaliação dos controles, os resultados são documentados e transformados em recomendações para melhoria dos processos.

2.8 Diagrama da Função do Auditor



O auditor atua como um elo entre tecnologia e gestão, avaliando se os recursos tecnológicos estão protegidos e alinhados aos objetivos organizacionais.

2.9 Tabela Comparativa - Técnicas de Auditoria

Técnica	Objetivo	Aplicação	Exemplo
Entrevista	Obter informações dos responsáveis pelos processos	Conversa com usuários e gestores	Questionar responsáveis sobre política de acesso
Análise documental	Verificar registros formais	Avaliação de documentos e relatórios	Conferir políticas de segurança
Observação in loco	Comparar teoria e prática	Acompanhamento das atividades	Verificar controle de entrada em servidores
Análise de sistemas	Avaliar funcionamento tecnológico	Inspeção de sistemas e registros	Analisar logs de acesso
Testes de controle	Confirmar eficácia dos controles	Simulação/verificação dos mecanismos existentes	Testar recuperação de backup

2.10 Tabela Comparativa - Tipos de Controle

Tipo de Controle	Objetivo	Característica	Exemplo
Preventivo	Evitar problemas	Atua antes do incidente	Autenticação multifator
Detectivo	Identificar falhas	Atua durante ou após o problema	Monitoramento de logs
Corretivo	Corrigir impactos	Atua após ocorrência	Recuperação de backup

2.11 Exemplos Práticos de Auditoria de TI

Exemplo 1 — Controle de Acesso

Situação: Uma empresa possui um sistema interno utilizado por diversos funcionários.

Problema identificado: Funcionários possuem permissões maiores do que as necessárias para suas funções.

Técnica aplicada pelo auditor:

- Entrevista com usuários;
- Análise documental das permissões;
- Teste de controle de acesso.

Resultado esperado: Aplicação do princípio do menor privilégio, garantindo que cada usuário tenha apenas os acessos necessários.

Exemplo 2 — Backup e Recuperação de Dados

Situação: Uma organização realiza backups diariamente, mas nunca testa a recuperação.

Problema identificado: Existe risco de os arquivos não serem restaurados em caso de falha.

Técnica aplicada: Observação in loco + teste de controle.

Recomendação: Criar testes periódicos de restauração para garantir a efetividade do processo.

Exemplo 3 — Segurança da Informação

Situação: Uma empresa apresenta registros de tentativas de acesso não autorizado.

Procedimento do auditor:

- Analisar logs;
- Identificar padrões de comportamento;
- Avaliar controles de segurança.

Recomendação: Melhorar o monitoramento, políticas de senha e mecanismos de autenticação.

2.12 Revisão dos Conceitos Técnicos

Após revisão dos conceitos apresentados, os principais termos utilizados neste trabalho são:

Conceito	Definição
Auditoria de TI	Processo sistemático de avaliação dos recursos tecnológicos
Auditor	Profissional responsável por analisar riscos e controles
Evidência	Informação utilizada para fundamentar conclusões
Controle interno	Procedimento criado para reduzir riscos
Teste de controle	Avaliação da eficiência dos controles existentes
Risco tecnológico	Possibilidade de falhas afetarem sistemas ou informações
Relatório de auditoria	Documento que apresenta resultados e recomendações

3 CONCLUSÃO

A Sprint 3 permitiu aprofundar os principais conceitos relacionados à função do auditor e às técnicas utilizadas em auditorias de Tecnologia da Informação.

Foi possível compreender que o auditor possui uma atuação estratégica, contribuindo para a identificação de riscos, avaliação dos controles internos e melhoria contínua dos processos organizacionais.

As técnicas de coleta de evidências, como entrevistas, análise documental e observação in loco, são essenciais para garantir que as conclusões da auditoria sejam fundamentadas em informações confiáveis. Além disso, os testes de controle e os relatórios de auditoria demonstram a importância de avaliar continuamente os ambientes tecnológicos para garantir segurança, eficiência e conformidade.

Já a inserção de diagramas, tabelas comparativas e exemplos práticos contribui para uma melhor compreensão dos conceitos relacionados à auditoria de Tecnologia da Informação. Esses recursos permitem visualizar o funcionamento do processo de auditoria, diferenciar técnicas utilizadas e compreender como os conhecimentos teóricos são aplicados em situações reais.

Além disso, a revisão dos conceitos técnicos reforça a precisão das informações apresentadas, garantindo que os termos utilizados estejam alinhados às boas práticas de auditoria e às referências estudadas.